Revisión Informe Seminario 1

OBSERVACIONES GENERALES DE FONDO

1. Validación incompleta: las líneas base (LB1 y LB2) definidas en 7.2 no se reportan en los resultados. No veo Precision@5 y Precision@10 comparados contra LB1 y LB2, la hipótesis no se puede evaluar.
2. Riesgo de evaluación circular: el ground truth de Precision@K se define con los mismos criterios que pondera el modelo. Se necesita un etiquetado independiente.
3. El modelo matemático no cumple la regla de negocio declarada ("la evidencia de ataque prioriza ineludiblemente"): hay contraejemplos (ver 6.2). El divisor 1,2 no es empírico, el modelo solo atenúa el CVSS, Ca = 1,0 no es neutro y los tres escenarios de 6.4 no validan los pesos. Hay errores de redondeo (4,17 y 4,71).
4. Correlación solo por IP: eleva todas las vulnerabilidades de un host ante cualquier alerta, aunque no tenga relación con el CVE.
5. MTTR mal operacionalizado: comparar el tiempo de cómputo con el tiempo humano no es MTTR. No hubo usuarios, aunque la Sección 7.8 se titula "Pruebas con Usuarios".
6. Inconsistencias arquitectónicas: KEV vía MISP local frente a petición directa a CISA frente a "API simulada". Integraciones por API frente a lectura de archivos JSON y "mocking". El endpoint /alerts no existe en la API de Wazuh. GMP entrega XML, no JSON.
7. Falta la sección de Conclusiones y Trabajo Futuro. El estado del arte es escaso y omite SSVC, que es un competidor directo. Hay referencias con errores ([2], [4], [6]) y una norma derogada (ISO/IEC 27005:2011), la última y cuarta edición es la de 2022.
8. Alinear título, objetivo general y alcance real: se trata de una prueba de concepto de priorización, no de una plataforma SOAR con respuesta.
9. Falta el repositorio del código y el anexo con el dataset (activos, CVE, eventos, ground truth) para asegurar la reproducibilidad.
10. El documento está bien estructurado y el problema está bien motivado. Las observaciones apuntan a que las conclusiones sean defendibles ante la comisión.

OBSERVACIONES GENERALES DE FORMA

- Separador decimal: unificar en coma (10,0; 4,17) en todo el texto, las ecuaciones y las tablas.
- Tiempos verbales: unificar en pretérito para el trabajo realizado (hoy se mezclan futuro y pasado, sobre todo en 7.3 y 8).
- Tono: evitar términos absolutos o sobredimensionados ("certifica", "demuestra", "a la perfección", "ineludiblemente", "sin latencia", "100 % auditable").
- Terminología: unificar alerta/vulnerabilidad, operativo/operacional e institución/cliente. Siglas: definir una sola vez (SOC, SOAR, RBVM y MTTR se redefinen varias veces). Considerar un glosario.
- Numeración: eliminar la numeración duplicada en 5.1.x y reiniciar la numeración de figuras y tablas de los anexos (A.1, A.2…).
- Figuras: exportar los diagramas UML en formato vectorial y a mayor tamaño (hoy son ilegibles impresos).